Société TALBAGO

Guide d’utilisation

Outil d’évaluation de la maturité en cybersécurité des environnements Cloud

Table des matières

1. Introduction à l'outil d'évaluation 3
   1.1 Objectif général 3
   1.2 Structure des domaines (Feuille Domaines) 3
   1.3 Débuter avec l'outil : Choisir un domaine 4
   1.4 Présentation de la feuille d'évaluation : 5
2. Echelles 6
3. Dashboard 7
4. Conseils de bonnes pratiques 9

1. Introduction à l'outil d'évaluation

1.1 Objectif général

Ce guide a pour objectif de présenter l'utilisation de l'outil d'évaluation de maturité en cybersécurité Cloud développé pour **TALBAGO**. Cet outil permet d'évaluer le niveau de maturité des pratiques de sécurité de l'organisation dans le cadre de l'utilisation et de l'exploitation d'environnements Cloud.

L'évaluation repose sur un modèle de maturité en sécurité Cloud permettant d'analyser les pratiques existantes et d'identifier les axes d'amélioration pour renforcer la posture de sécurité.

Le modèle utilisé s'inspire de plusieurs référentiels et cadres de bonnes pratiques reconnus en cybersécurité, notamment :

- Les recommandations de la **Cloud Security Alliance (CSA)** ;
- La **Cloud Controls Matrix (CCM)** ;
- Le **NIST Cybersecurity Framework (NIST CSF)**.

L'évaluation est structurée autour de plusieurs domaines de sécurité Cloud, regroupant des pratiques et objectifs de contrôle permettant d'estimer le niveau de maturité de l'organisation.

L'outil permet ainsi de :

- Évaluer le niveau de maturité de sécurité Cloud de l'organisation ;
- Identifier les écarts par rapport aux bonnes pratiques ;
- Disposer d'une vision structurée des domaines de sécurité à améliorer.

1.2 Structure des domaines (Feuille Domaines)

L'outil d'évaluation repose sur un ensemble de domaines de sécurité cloud permettant d'analyser les différents aspects de la cybersécurité dans un environnement cloud.

Afin de structurer l'évaluation, ces domaines sont regroupés en trois grandes catégories :

Domaines fondamentaux

Les domaines fondamentaux couvrent les éléments essentiels permettant d'encadrer l'adoption du cloud au sein de l'organisation. Ils définissent les principes de gouvernance, d'organisation et de gestion des identités nécessaires pour gérer les environnements cloud de manière sécurisée.

Ces domaines incluent notamment :

- Gouvernance
- Organisation Management
- IAM (Identity and Access Management)
- Supervision de la sécurité

Ils permettent d'établir les politiques de sécurité, les responsabilités et les mécanismes de contrôle nécessaires pour encadrer l'utilisation du cloud.

Domaines structurels

Les domaines structurels concernent la sécurisation des composants techniques de l'infrastructure cloud. Ils couvrent les mécanismes techniques nécessaires pour protéger les ressources, les réseaux, les applications et les données.

Ces domaines incluent notamment :

- Sécurité réseau
- Sécurité des charges de travail

- Sécurité applicative
- Protection des données

Ces domaines permettent d'évaluer la mise en place des contrôles techniques de sécurité au sein de l'infrastructure cloud.

Domaines procéduraux

Les domaines procéduraux décrivent les processus organisationnels et opérationnels nécessaires pour maintenir la sécurité dans le temps.
Ils permettent d'évaluer la capacité de l'organisation à gérer les risques, assurer la conformité et répondre aux incidents de sécurité.
Ces domaines incluent notamment :

- Évaluation des risques et gestion des fournisseurs
- Résilience
- Conformité et audit
- Réponse aux incidents

Ces domaines permettent d'évaluer la maturité des processus de gouvernance et de gestion de la sécurité cloud au sein de l'organisation.

1.3 Débuter avec l'outil : Choisir un domaine

L'outil d'évaluation est structuré autour de plusieurs domaines de sécurité Cloud. Chaque domaine correspond à une feuille spécifique dans le fichier Excel et regroupe un ensemble de contrôles permettant d'évaluer un aspect particulier de la cybersécurité des environnements Cloud.

Pour commencer l'évaluation, l'utilisateur doit sélectionner un domaine et analyser les contrôles associés afin de déterminer le niveau de maturité de l'organisation pour ce domaine.

Chaque feuille Excel correspond ainsi à un domaine de sécurité et contient :

- Un identifiant de contrôle (ID) ;
- Le nom du contrôle ;
- Une description du contrôle ;
- Un niveau de maturité à attribuer ;
- Un libellé de maturité ;
- Une signification du niveau de maturité.

L'évaluation consiste à examiner chaque contrôle et à attribuer le niveau de maturité correspondant à la situation de l'organisation.

Les domaines couverts par l'outil sont les suivants :

- Gouvernance
- Gestion organisationnelle
- Gestion des identités et des accès (IAM)
- Supervision de la sécurité
- Sécurité réseau
- Sécurité des charges de travail
- Sécurité applicative
- Protection des données
- Évaluation des risques et gestion des fournisseurs
- Résilience
- Conformité et audit
- Réponse aux incidents

Chaque domaine permet d'évaluer un ensemble cohérent de pratiques de sécurité. L'analyse peut être réalisée domaine par domaine afin d'obtenir une vision progressive et structurée du niveau de maturité de l'organisation.
Une fois le domaine sélectionné, l'utilisateur peut commencer l'évaluation en attribuant un niveau de maturité aux différents contrôles présents dans la feuille correspondante.

1.4 Présentation de la feuille d'évaluation :

Une fois le domaine sélectionné, l'utilisateur accède à une feuille d'évaluation contenant un tableau permettant d'analyser les différents contrôles de sécurité associés à ce domaine.

Chaque feuille suit la même structure. À titre d'exemple, la figure ci-dessous présente une partie de la feuille correspondant au domaine **Gouvernance**.

ID	Nom du contrôle	Description du contrôle	Niveau de maturité	Libellé	Signification
GOV-02.1	Fournisseurs cloud approuvés	L'organisation a identifié et validé les fournisseurs cloud autorisés à être utilisés.	4	Maîtrisé	La sécurité est centralisée et largement automatisée. Elle est intégrée dans l'Infrastructure as Code et les pipelines de déploiement.
GOV-03.1	Existence d'un Cloud Center of Excellence (CCoE)	Un Cloud Center of Excellence (CCoE), un Cloud Council ou une équipe centrale de gouvernance cloud est en place pour guider l'adoption et l'utilisation du cloud. Pour un niveau de maturité 3, cette équipe peut encore être en phase de structuration. Dans les organisations plus petites, ce rôle peut être assuré par l'équipe IT ou sécurité existante, sans qu'un CCoE formel soit nécessaire.	1	Initiale	La sécurité est gérée manuellement et de manière non structurée. Peu d'utilisation des fonctionnalités avancées du cloud et IAM peu organisé.

Chaque ligne du tableau correspond à un contrôle de sécurité à évaluer. L'utilisateur doit analyser chaque contrôle et attribuer un niveau de maturité en fonction du niveau de mise en œuvre observé dans l'organisation.

Le tableau est composé des colonnes suivantes :

- **Colonnes descriptives (informatives)**
  Ces colonnes permettent de comprendre le contrôle évalué et ne doivent pas être modifiées.
  - **ID** : Identifiant unique du contrôle permettant de le référencer.
  - **Nom du contrôle** : Intitulé du contrôle de sécurité à évaluer.
  - **Description du contrôle** : Description détaillée du contrôle permettant de comprendre l'objectif de sécurité attendu.

- **Colonnes d'évaluation**
  Ces colonnes sont utilisées dans le cadre de l'évaluation.
  - **Niveau de maturité** : Champ à renseigner par l'utilisateur. Il correspond au niveau de maturité atteint par l'organisation pour le contrôle évalué.
  - **Libellé** : Indique automatiquement l'intitulé correspondant au niveau de maturité sélectionné (par exemple : Initial, Défini, Maîtrisé, Optimisé).
  - **Signification** : Fournit une description du niveau de maturité sélectionné afin d'aider l'utilisateur à interpréter le résultat.

- **Colonne de justification**
  - **Commentaires** : Champ libre permettant à l'utilisateur de justifier le niveau de maturité attribué, de préciser les éléments observés ou d'ajouter des remarques utiles à l'analyse.

L'utilisateur doit parcourir l'ensemble des contrôles du domaine et attribuer un niveau de maturité pour chaque ligne du tableau. Les informations renseignées permettent ensuite d'alimenter les indicateurs de maturité et les tableaux de bord de l'outil.

2. Echelles

L'évaluation des contrôles repose sur un modèle de maturité à cinq niveaux permettant d'estimer le degré de mise en œuvre des pratiques de sécurité au sein de l'organisation.

Chaque niveau correspond à **un** stade de progression dans la structuration et l'automatisation de la cybersécurité des environnements Cloud**.**

La figure ci-dessous présente les différents niveaux de maturité utilisés dans l'outil.

Niveau de maturité	
Initiale	La sécurité est gérée manuellement et de manière non structurée. Peu d'utilisation des fonctionnalités avancées du cloud et IAM peu organisé.
Répétable	Des politiques de sécurité existent, mais elles sont appliquées manuellement et de façon incohérente selon les équipes. L'automatisation et le MFA sont encore limités.
Défini	Les politiques de sécurité sont centralisées et standardisées. Certaines automatisations apparaissent et des outils de sécurité cloud commencent à être utilisés.
Maîtrisé	La sécurité est centralisée et largement automatisée. Elle est intégrée dans l'Infrastructure as Code et les pipelines de déploiement.
Optimisé	La sécurité est entièrement intégrée, automatisée et pilotée par des plateformes centralisées. Les contrôles sont cohérents et appliqués à grande échelle.
Non applicable	Le contrôle ne s'applique pas au contexte, à l'architecture ou aux technologies utilisées par l'organisation. Il est donc exclu de l'évaluation de maturité pour cet environnement.

Les niveaux sont définis comme suit :

Niveau 1 — Initiale

La sécurité est gérée manuellement et de manière non structurée.
Les processus de sécurité sont peu formalisés et reposent principalement sur des actions ponctuelles ou réactives.
L'utilisation des fonctionnalités avancées du cloud est limitée et la gestion des identités et des accès (IAM) reste peu organisée.

Niveau 2 — Répétable

Certaines politiques ou pratiques de sécurité existent, mais leur mise en œuvre reste principalement manuelle et peut varier selon les équipes ou les projets.
Les contrôles de sécurité sont appliqués de manière partielle et l'automatisation ainsi que certains mécanismes de protection (comme l'authentification multifactorielle) restent limités.

Niveau 3 — Défini

Les politiques de sécurité sont formalisées, centralisées et appliquées de manière plus cohérente.
Les processus de sécurité commencent à être standardisés et certaines automatisations ou outils de sécurité Cloud sont progressivement intégrés dans les pratiques de l'organisation.

Niveau 4 — Maîtrisé

La sécurité est largement structurée et automatisée.
Les contrôles de sécurité sont intégrés dans les processus techniques, notamment dans l'Infrastructure as Code et les pipelines de déploiement. Les pratiques de sécurité sont cohérentes et appliquées de manière systématique.

Niveau 5 — Optimisé

La sécurité est pleinement intégrée dans l'organisation et repose sur des plateformes et des processus centralisés. Les contrôles de sécurité sont automatisés, cohérents et appliqués à grande échelle, permettant une gestion proactive et continue de la cybersécurité.

Non applicable (N/A)

Dans certains cas, un contrôle peut ne pas être pertinent pour l'organisation, en raison de son contexte, de son architecture ou des technologies utilisées.
Lorsque cela se produit, le contrôle peut être marqué comme **Non applicable** et il est alors exclu du calcul du niveau de maturité.

3. Dashboard

Pour faciliter l'analyse des résultats, l'outil génère automatiquement un tableau de bord pour chaque domaine évalué.

Ces tableaux de bord permettent de visualiser rapidement les résultats de l'évaluation, d'identifier les forces et les faiblesses de l'organisation et d'obtenir une vision synthétique du niveau de maturité atteint.

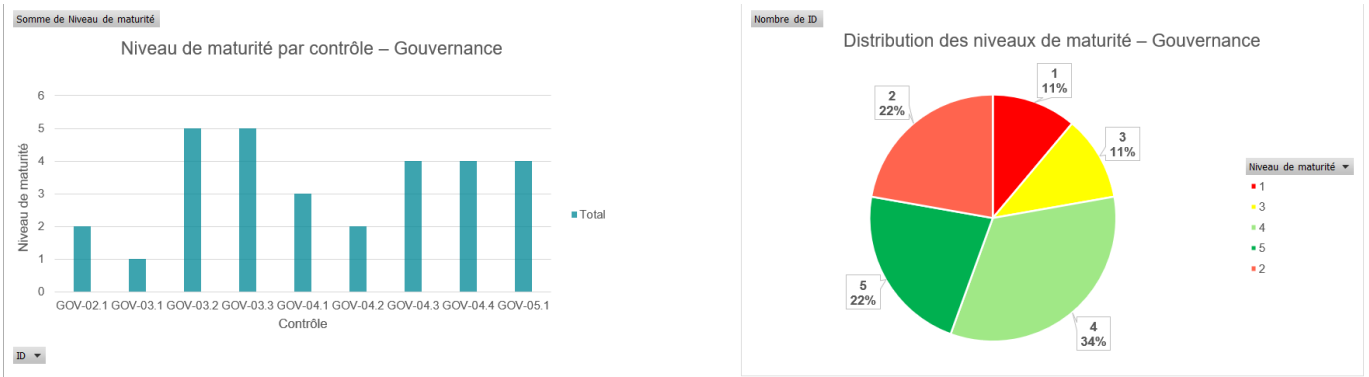
Chaque tableau de bord est alimenté automatiquement à partir des niveaux de maturité renseignés dans la feuille d'évaluation du domaine correspondant.

Les tableaux de bord permettent notamment de :

- Visualiser le niveau de maturité des différents contrôles ;
- Identifier les contrôles les plus faibles ou les plus matures ;
- Observer la distribution globale des niveaux de maturité ;
- Disposer d'un indicateur synthétique du niveau de maturité du domaine.

Exemple : Tableau de bord du domaine Gouvernance

La figure ci-dessous présente un exemple de tableau de bord généré pour le domaine **Gouvernance**.



Gouvernance	**3,555555556**

Ce tableau de bord comporte deux visualisations principales.

- **Niveau de maturité par contrôle**

Le graphique en barres présente le niveau de maturité attribué à chaque contrôle du domaine.

Chaque barre correspond à un contrôle spécifique (par exemple : GOV-02.1, GOV-03.1, etc.).

Ce graphique permet d'identifier rapidement :

- Les contrôles présentant un niveau de maturité faible ;
- Les contrôles déjà bien maîtrisés ;
- Les écarts entre les différents contrôles du domaine.

Cette visualisation aide à repérer les points faibles prioritaires à améliorer.

- **Distribution des niveaux de maturité**

Le graphique circulaire présente la **répartition globale des niveaux de maturité pour l'ensemble des contrôles du domaine**.

Il permet d'observer la proportion de contrôles évalués aux différents niveaux (1 à 5). Cette représentation facilite l'identification :

- Du niveau global de maturité du domaine ;
- De la part des contrôles nécessitant des améliorations ;
- Du degré de progression de l'organisation vers des niveaux de maturité plus élevés.

Indicateur global de maturité

Le tableau de bord affiche également un niveau moyen de maturité pour le domaine, calculé automatiquement à partir des évaluations réalisées.

Cet indicateur permet d'obtenir une vision synthétique du niveau de maturité global du domaine.

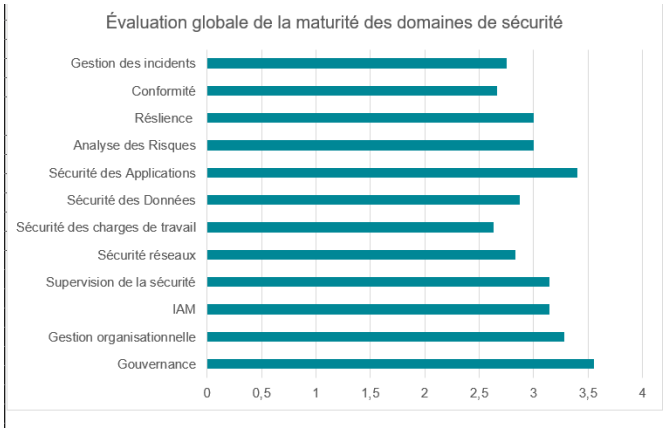
Le même principe de tableau de bord est appliqué à l'ensemble des domaines de l'outil, permettant ainsi d'analyser rapidement les résultats pour chaque aspect de la sécurité cloud.

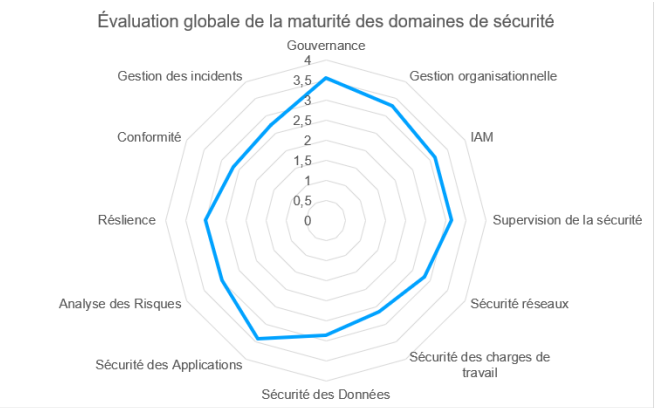
En complément des tableaux de bord propres à chaque domaine, l'outil propose également une évaluation globale de la maturité de sécurité cloud.

Cette vue permet d'obtenir une synthèse des résultats pour l'ensemble des domaines évalués, afin d'identifier rapidement les domaines les plus matures ainsi que ceux nécessitant des améliorations prioritaires.

Les indicateurs globaux sont calculés automatiquement à partir des niveaux de maturité attribués dans les différentes feuilles d'évaluation.

La figure ci-dessous présente un exemple d'évaluation globale de la maturité des domaines de sécurité.





Deux types de visualisations sont proposés.

- **Comparaison des niveaux de maturité par domaine**

Le graphique en barres présente le niveau de maturité moyen pour chaque domaine de sécurité.

Cette visualisation permet :

  - D'identifier les domaines les plus matures ;
  - De repérer les domaines présentant un niveau de maturité plus faible ;
  - De comparer rapidement les différents domaines de sécurité.

Elle facilite ainsi la priorisation des actions d'amélioration.

- **Vision globale de la maturité (radar)**

Le graphique radar offre une représentation synthétique de la maturité de l'organisation sur l'ensemble des domaines.

Chaque axe du graphique correspond à un domaine de sécurité. La forme du graphique permet d'observer rapidement :

  - Les domaines les plus avancés ;
  - Les domaines nécessitant un renforcement ;
  - L'équilibre global de la posture de sécurité.

Cette représentation permet d'avoir une vision stratégique de la maturité de cybersécurité cloud de l'organisation.

4. Conseils de bonnes pratiques

- ✓ Réaliser l'autoévaluation en équipe (informatique, SSI, direction métier. . .) pour croiser les points de Vue.
- ✓ Attribuer les niveaux de maturité de manière honnête, même si cela révèle des faiblesses. Le but est L'amélioration continue.
- ✓ Ajouter des commentaires pour justifier les notes et noter les actions à envisager.
- ✓ Réévaluer les contrôles tous les 6 à 12 mois pour suivre les progrès et ajuster les priorités